



AAiT

ADDIS ABABA INSTITUTE OF TECHNOLOGY
አዲስ አበባ ቴክኖሎጂ ኢንስቲትዩት
ADDIS ABABA UNIVERSITY
አዲስ አበባ ዩኒቨርሲቲ

Fundamentals of Cybersecurity Group Assignment

Cybersecurity Risk Assessment and Mitigation Report for The New Age Bank

Group Members

No	Name	ID	Task	Section
1.	Blen Berhanu	UGR/8682/15	Acknowledgment, Introduction, P8 - Suppliers(1-4)	4
2.	Eyerusalem Geremew	UGR/2359/15	X4 - ICT Support Contract(5-8)	3
3.	Semawit Nega	UGR/5637/15	X4 - ICT Support Contract(1-4)	3
4.	Nuhamin Arega	UGR/1151/15	P8 - Building	2
5.	Yonathan Desalegn	UGR/4871/15	P8 - Suppliers(5-8)conclusion	1

Submission Date: March 25, 2025
Submitted to : Senait Desalegn

TABLE OF CONTENT

Acknowledgment.....	1
Introduction.....	2
Asset Under Review: People Asset P8-Suppliers.....	3
1. Risk Assessment for P8 - Suppliers.....	3
1.1 Asset Overview.....	3
1.2 Risk Scenarios Development.....	3
1.3 Threats and Vulnerabilities Identification.....	4
1.4 Risk Analysis (Likelihood, Impact, and Risk Level).....	4
2. Risk Mitigation Strategies.....	5
2.1 For Scenario 1: Supplier Compromise Leading to Unauthorized Access.....	5
2.2 For Scenario 2: Supplier Mishandling or Leaking Sensitive Information.....	5
3. Applicable Cybersecurity Controls and Justifications.....	6
4. Justification for Selected Controls.....	7
5. Risk Assessment Methodology Implementation.....	8
6. Quality of the Risk Assessment.....	8
7. Applicability of Mitigation Strategies and Controls.....	8
8. Structure, Completeness, and Quality of the Report.....	8
Asset Under Review: X4 - ICT support contract.....	9
Introduction.....	9
1. Risk Assessment for X4 - ICT support contract.....	10
1.1 Asset Overview.....	11
1.2 Risk Scenarios Development.....	11
1.3 Threats and Vulnerabilities Identification.....	11
2. Risk Mitigation Strategies.....	11
2.1 For Scenario 1: Unauthorized Access via ICT Contractor Remote Tools.....	11
2.2 For Scenario 2: Contractor Mishandling or Data Leakage.....	12
3. Applicable Cybersecurity Controls and Justifications.....	12
4. Justification for Selected Controls.....	12
5. Risk Assessment Methodology Implementation.....	13
7. Applicability of Mitigation Strategies and Controls.....	13
8. Structure, Completeness, and Quality of the Report.....	13
Asset Under Review: People Asset P8-Building.....	14
Introduction.....	14
1. Risk Scenarios.....	15
1.1 Scenario 1: Unauthorized Physical Access.....	15
1.2 Scenario 2: Insider Threat – Disgruntled Employee.....	17
2. Risk Mitigation Strategies.....	18
3. Cybersecurity Controls & Justification.....	18
Conclusion.....	20
Reference.....	21
Appendix.....	2

Acknowledgment

We would like to express our sincere gratitude to our instructor, Senait Desalegn, for her invaluable guidance, support, and encouragement throughout the completion of this Cybersecurity Risk Assessment Report for New Age Bank (NAB). Her insightful feedback and deep expertise in cybersecurity have greatly contributed to our understanding and the quality of this report.

We would also like to extend our appreciation to our team members for their dedication, collaboration, and hard work in conducting this assessment. The collective effort in researching, analyzing, and documenting the risks and mitigation strategies has been instrumental in producing this comprehensive report.

Finally, we acknowledge the importance of teamwork and constructive discussions in successfully completing this project. This experience has enhanced our knowledge and skills in cybersecurity risk assessment, and we are grateful for the opportunity to learn and grow through this process.

Thank you.

Introduction

Cybersecurity Risk Assessment Report for New Age Bank (NAB)

In an era where financial institutions are prime targets for cyber threats, conducting a comprehensive cybersecurity risk assessment is critical to safeguarding operations, sensitive data, and customer trust. New Age Bank (NAB) recognizes the importance of identifying, analyzing, and mitigating cybersecurity risks across its digital and physical assets.

This cybersecurity risk assessment follows the NIST SP 800-30 Risk Assessment Methodology, which provides a structured approach to evaluating threats, vulnerabilities, and risks associated with NAB's critical assets. The focus of this assessment includes:

- People Asset (P8 - Suppliers) – Evaluating cybersecurity risks posed by third-party vendors and service providers.
- Service Asset (X4 - ICT Support Contracts) – Assessing the security risks linked to third-party contractors who provide IT infrastructure support.
- Physical Asset (P8 - Building) – Identifying potential threats to NAB's headquarters, including unauthorized access and insider risks.

The assessment aims to:

1. Identify critical cybersecurity risks related to external suppliers, IT service providers, and physical security.
2. Analyze potential threats, vulnerabilities, and real-world risk scenarios.
3. Evaluate the likelihood and impact of each risk, classifying them based on severity.
4. Recommend mitigation strategies and cybersecurity controls aligned with NIST 800-53 to strengthen NAB's security posture.

New Age Bank – Cybersecurity Risk Assessment Report

Asset Under Review: People Asset P8-Suppliers

1. Risk Assessment for P8 - Suppliers

1.1 Asset Overview

- **Asset Name:** Suppliers
- **Asset Number:** P8
- **Asset Owner:** Marketing Manager
- **Value:** Medium (M)
- **Security Access:** N/A
- **Location:** N/A (Intangible Asset)

Description: suppliers with contracts for services such software solutions, equipment supply, marketing services, and IT support. Depending on their involvement, these suppliers can have different degrees of access to NAB facilities, systems, or private data.

1.2 Risk Scenarios Development

Scenario 1: Supplier Compromise Leading to Unauthorized Access

Description: Cybercriminals compromise a supplier who has permissioned access to NAB's network or systems. The attackers get access to NAB's internal systems by taking advantage of the supplier's trust relationship or access credentials.

Example: A supplier providing software maintenance falls victim to a phishing attack. Their compromised credentials are used by cybercriminals to gain unauthorized access to NAB's customer data system.

Consequences:

- Unauthorized access to sensitive financial data.
- Potential data breaches affecting customer trust.
- Regulatory penalties for non-compliance (e.g., NBE regulations, GDPR).

Scenario 2: Supplier Mishandling or Leaking Sensitive Information

Description: When a supplier that has access to private data about NAB's clients or internal processes treats it improperly, it may be accidentally revealed or purposefully leaked.

Example: A marketing supplier collects customer data for a campaign but stores it insecurely on their local system. The data is later exfiltrated due to a ransomware attack on their network.

Consequences:

- Breach of customer privacy and confidentiality.
- Reputational damage leading to customer attrition.
- Potential lawsuits or regulatory fines.

1.3 Threats and Vulnerabilities Identification

Threats	Vulnerabilities
Cyber-attacks targeting third-party suppliers (malware, phishing)	Inadequate supplier security practices and cyber hygiene
Insider threat from supplier employees (espionage, sabotage)	Lack of due diligence in vetting supplier personnel
Unintentional data leaks by suppliers	Absence of formal data handling policies and procedures for suppliers
Exploitation of supplier systems to access NAB's environment	Excessive access privileges granted to suppliers beyond their operational requirements
Third-party vendors' failure to comply with security regulations	Lack of periodic audits and compliance assessments of supplier security control

1.4 Risk Analysis (Likelihood, Impact, and Risk Level)

Risk Explanation:

Likelihood of supplier compromise is **high** due to increased cybercriminal targeting of third-party suppliers, often perceived as weak links.

Impact is **high**, considering NAB's reliance on supplier services and potential exposure of sensitive financial and customer data.

2. Risk Mitigation Strategies

2.1 For Scenario 1: Supplier Compromise Leading to Unauthorized Access Mitigation Strategies:

1. Implement a Robust Third-Party Risk Management (TPRM) Program

- Conduct security due diligence before onboarding suppliers (assess their cybersecurity practices, certifications such as ISO 27001, etc.).
- Classify suppliers based on risk and data/system access levels.

2. Enforce Strict Access Control Policies

- Apply the Principle of Least Privilege (POLP): Suppliers should only have access to systems and data required for their function.
- Regularly review and revoke unnecessary supplier access rights.

3. Use Network Segmentation

- Suppliers accessing NAB's environment should be restricted to segmented, monitored network zones.

4. Require Multi-Factor Authentication (MFA)

- Suppliers accessing NAB's critical systems should be required to use MFA to prevent unauthorized access through compromised credentials.

2.2 For Scenario 2: Supplier Mishandling or Leaking Sensitive Information

Mitigation Strategies:

1. Formalize Data Handling and Protection Requirements

- Define clear policies and procedures regarding data classification, storage, and sharing for suppliers.
- Ensure all suppliers handling NAB's data are contractually obligated to comply with these policies.

2. Incorporate Non-Disclosure Agreements (NDAs) and Data Protection Clauses

- Legally bind suppliers to confidentiality and data protection obligations.
- Include penalties and termination clauses for non-compliance.

3. Conduct Regular Training and Awareness Programs

- Educate supplier staff on NAB's data security policies, incident reporting procedures, and phishing awareness.

4. Perform Periodic Supplier Security Audits

- Audit suppliers' compliance with NAB's security requirements regularly (annually or semi-annually).

3. Applicable Cybersecurity Controls and Justifications

Risk Scenario	Cybersecurity Control (NIST 800-53)	Justification
Supplier Compromise Leading to Unauthorized Access	SA-12 (Supply Chain Protection) AC-6 (Least Privilege) IA-2 (Identification & Authentication) SC-7 (Boundary Protection)	Ensures suppliers implement adequate security practices and are granted limited access. MFA and network segmentation enhance access protection.
Supplier Mishandling or Leaking Sensitive Information	PL-2 (System and Communications Protection Policy) PS-7 (Third-Party Personnel Security) CA-7 (Continuous Monitoring)	Clearly defined policies guide supplier behavior. Continuous monitoring detects non-compliance, and legal agreements mitigate liability risks.

4. Justification for Selected Controls

1. SA-12 (Supply Chain Protection):

Vital for ensuring third-party suppliers meet minimum cybersecurity requirements. Protects the supply chain by vetting, assessing, and monitoring supplier activities.

2. AC-6 (Least Privilege):

Limits the damage in case a supplier's account is compromised by restricting access to only what is strictly necessary.

3. IA-2 (Identification & Authentication):

MFA and strong authentication mechanisms prevent unauthorized supplier access through compromised credentials.

4. SC-7 (Boundary Protection):

Implements network segmentation to limit the spread of an attack from a supplier compromise to NAB's internal systems.

5. PL-2 (System and Communications Protection Policy):

Provides a framework for data handling requirements, ensuring suppliers know and follow NAB's security policies.

6. PS-7 (Third-Party Personnel Security):

Ensures suppliers' employees are appropriately vetted and informed of their responsibilities regarding NAB's data.

7. CA-7 (Continuous Monitoring):

Detects policy violations and security incidents in real-time, allowing NAB to take immediate corrective action.

5. Risk Assessment Methodology Implementation

Methodology Used: NIST SP 800-30 Risk Assessment Process

Steps Followed:

1. Asset identification and value assignment.
2. Development of realistic risk scenarios.
3. Threat and vulnerability analysis.
4. Likelihood and impact determination to assess risk level.
5. Risk mitigation strategy development.
6. Control selection based on NIST SP 800-53 guidelines.

6. Quality of the Risk Assessment

- ☐ Focused on a critical asset (P8: Suppliers), relevant to modern cybersecurity threats.
- ☐ Detailed analysis provided for both external and insider threats.
- ☐ Comprehensive assessment of vulnerabilities that can be exploited by attackers.
- ☐ Realistic and practical risk scenarios demonstrating an understanding of the operational environment of NAB.

7. Applicability of Mitigation Strategies and Controls

- ☐ Controls are directly applicable to the asset and the identified risks.
- ☐ Strategies align with NAB's operational needs and regulatory requirements.

- Controls are selected from NIST SP 800-53, ensuring industry-standard compliance and robust security postures.

8. Structure, Completeness, and Quality of the Report

- The report follows a logical structure based on NIST methodology.
- Comprehensive in terms of addressing all assignment instructions.

Asset Under Review: X4 - ICT support contract

1. Introduction

A cybersecurity risk assessment following the NIST SP 800-30 Risk Assessment Methodology is being conducted at New Age Bank (NAB). This section focuses on **ICT Support Contracts**, which are a critical component of NAB's service assets. These contracts often involve external service providers who maintain, upgrade, and support NAB's IT infrastructure. While these services are essential, they may also introduce cybersecurity risks due to their access to NAB's systems, software, and sensitive operational environments.

1. Risk Assessment for X4 - ICT support contract

1.1 Asset Overview

- **Asset Name:** ICT support contract
- **Asset Number:** X4
- **Asset Owner:** Chief Information Officer (CIO)
- **Value:** Medium (M)
- **Security Access:** Restricted
- **Location:** External

Description: Agreements with third-party service providers responsible for supporting NAB's IT infrastructure, including hardware/software maintenance, network troubleshooting, system upgrades, and remote technical assistance.

1.2 Risk Scenarios Development

Scenario 1: Unauthorized Access via ICT Contractor Remote Support Tools

Description: A contractor uses a remote access tool to support NAB systems.

Attackers compromise this tool or steal access credentials, gaining entry into NAB's internal environment.

Example: A remote support tool used by the contractor is not patched and becomes a vulnerability point exploited by ransomware attackers.

Consequences:

- Unauthorized access to NAB infrastructure.
- Disruption of critical banking services.
- Malware/ransomware propagation within internal systems.

Scenario 2: ICT Contractor Negligence or Data Mishandling

Description: The contractor improperly handles sensitive system configuration files or fails to follow secure update procedures, leading to exposure of internal system data.

Example: A contractor stores system credentials on an unencrypted personal device, which is later stolen.

Consequences:

- Leakage of critical infrastructure data.
- Loss of customer trust due to security lapse.
- Legal liability and regulatory penalties.

1.3 Threats and Vulnerabilities Identification

Threats	Vulnerabilities
Remote access exploitation	Insecure remote support tools or weak authentication
Insider threat (contractor personnel misconduct)	Lack of monitoring and contractor onboarding vetting
Mishandling of sensitive files	No contractor data handling protocol

Threats	Vulnerabilities
Unauthorized software or tool installation	Absence of change management policies
Third-party tool vulnerabilities	Delayed updates or vendor patching cycles

- **Likelihood: High** – Due to remote access practices and external dependence.
- **Impact: High** – Potential access to core infrastructure and sensitive data.
- **Risk Level: High**

2. Risk Mitigation Strategies

2.1 For Scenario 1: Unauthorized Access via ICT Contractor Remote Tools

- Implement **VPN with MFA** for contractor access.
- Enforce **contractor device compliance policies** (e.g., only bank-approved tools).
- Schedule **access time restrictions and monitoring**.
- Perform **security validation on all contractor-provided tools**.
- Log all remote access activities and **enable SIEM alerting**.

2.2 For Scenario 2: Contractor Mishandling or Data Leakage

- Define secure configuration and credential handling **procedures** in contracts.
- Mandate encryption for contractor device storage.
- Include data classification training for contractors.
- Enforce NDA and SLAs with specific cybersecurity requirements.
- Revoke credentials immediately upon contract termination.

3. Applicable Cybersecurity Controls and Justifications

Risk Scenario	Cybersecurity Control (NIST 800-53)	Justification
Unauthorized Access	AC-17 (Remote Access), IA-2 (Identification and Authentication), SC-12 (Cryptographic Key Establishment)	Ensure secure remote access and authentication for external contractors.
Mishandling/Data Leakage	PL-2 (System & Communications Protection Policy), PS-7 (Third-party Personnel Security), MP-5 (Media Transport Protection)	Establish contractor handling protocols and legal obligations for secure data treatment.

4. Justification for Selected Controls

- **AC-17 (Remote Access):** Controls remote access tools, enforcing secure configurations and logging.
- **IA-2 (Identification and Authentication):** Ensures contractor access is properly authenticated with MFA.
- **SC-12 (Cryptographic Key Establishment):** Mandates encryption of sensitive communications.
- **PL-2 (System Protection Policy):** Defines how contractors should handle internal configuration and data.
- **PS-7 (Third-party Personnel Security):** Enforces contractor personnel vetting and training.
- **MP-5 (Media Transport Protection):** Ensures secure storage/transfer of sensitive files and configurations.

5. Risk Assessment Methodology Implementation

- Followed **NIST SP 800-30**:
 1. Asset identification (X4 – ICT Support Contracts).
 2. Risk scenario development.

3. Threats and vulnerabilities identification.
4. Likelihood and impact assessment.
5. Mitigation strategies development.
6. Cybersecurity control selection based on **NIST 800-53**.

6. Quality of the Risk Assessment

- Focused on critical third-party service delivery asset.
- Real-world scenarios reflecting remote access and contractor risks.
- Practical risk mitigations aligned with common cyberattack vectors.

7. Applicability of Mitigation Strategies and Controls

- Controls selected based on actual contractor behavior and access type.
- Supports NAB's secure operation of core IT systems.
- Enhances third-party assurance and reduces attack surface.

8. Structure, Completeness, and Quality of the Report

- Aligned with NIST SP 800-30 risk assessment structure.
- Clearly defined asset, scenarios, risks, controls, and justification.
- Suitable for management or auditor-level review.

Asset Under Review: People Asset P8-Building

1.Introduction

As part of the New Age Bank (NAB) cybersecurity risk assessment, conducted using the NIST SP 800-30 Risk Assessment Methodology, this report focuses on physical security risks associated with the bank's headquarters building.

- **Owner/Department:** CEO
- **Location:** Addis Ababa
- **Value:** High
- **Security Access:** Restricted

1. Risk Scenarios

1.1 Scenario 1: Unauthorized Physical Access

Scenario Description:

An attacker gains unauthorized access to the bank's headquarters by tailgating an employee or using a stolen/duplicated access card. Once inside, the attacker installs a rogue device on the bank's network to intercept sensitive banking data or steals confidential documents containing customer information.

Threats:

- Tailgating (Following an authorized employee into a restricted area)
- Stolen access credentials (Lost or duplicated keycards, stolen biometric data)
- Social engineering (Impersonating a technician or delivery person to gain entry)

Vulnerabilities:

- Lack of strict multi-factor authentication (MFA) for building access
- Weak visitor management policies (e.g., no escort required for visitors)
- No real-time access monitoring (e.g., outdated security cameras or logs not reviewed)

Likelihood & Impact Analysis:

Factor	Assessment
Likelihood	High (Banks are prime targets for unauthorized access attempts)
Impact	High (Compromise of sensitive data, financial loss, reputational damage)
Overall Risk Level	High

Risk Mitigation Strategies:

- Implement **biometric authentication and multi-factor authentication (MFA)** for entry.
- Upgrade **physical security systems** (AI-powered surveillance cameras, motion detectors).
- Enforce **visitor registration & escort policy** (All visitors must be accompanied by an employee).
- Conduct **regular security audits** (Review access logs and check for anomalies).

1.2 Scenario 2: Insider Threat – Disgruntled Employee**Scenario Description:**

A disgruntled employee with authorized access to the bank's headquarters intentionally disables security systems (e.g., CCTV cameras, access controls) or leaks sensitive financial data to external attackers. The employee might also plant malware or ransomware on internal servers to disrupt operations.

Threats:

- Intentional sabotage (Tampering with security systems, disabling alarms)
- Data theft (Copying or leaking confidential customer and bank data)
- Collaboration with cybercriminals (Providing inside information for targeted attacks)

Vulnerabilities:

- Lack of strict access control & monitoring (Employees may access areas they don't need)
- No real-time behavior monitoring for employees with critical access
- Weak offboarding procedures (Ex-employees may retain access rights)

Likelihood & Impact Analysis:

Factor	Assessment
Likelihood	Medium (While insider threats are less frequent than external attacks, they can be devastating)
Impact	High (Sabotage, data leaks, and financial fraud can severely damage the bank)
Overall Risk Level	High

2.Risk Mitigation Strategies:

- Implement **strict access control & privilege management** (Employees only access areas relevant to their role).
- Utilize **real-time employee monitoring** (AI-powered monitoring for unusual behavior).
- Conduct **background checks before hiring & during employment** (Identify potential insider risks).
- Enforce **strict offboarding procedures** (Immediately revoke access upon resignation/termination).
- Implement **Data Loss Prevention (DLP) tools** (Prevent unauthorized data transfers).

3. Cybersecurity Controls & Justification

Control (NIST SP 800-53)	Justification
PE-2: Physical Access Authorization	Ensures only authorized personnel can access restricted areas, reducing unauthorized entry risks.
PE-3: Physical Access Control	Strengthens security by implementing multi-factor authentication for building access.
PE-6: Monitoring Physical Access	Enables real-time tracking of individuals entering and exiting sensitive areas.

PE-9: Power Equipment and Cabling Protection	Prevents sabotage or tampering with critical security systems.
PS-3: Personnel Screening	Helps identify potential insider threats before hiring and during employment.
SI-4: System Monitoring	Detects unusual employee behavior that may indicate an insider threat.
AC-2: Account Management	Ensures that ex-employees or unauthorized personnel cannot retain access.
IR-4: Incident Handling	Defines a structured response plan for security incidents, minimizing damage.

Conclusion

This cybersecurity risk assessment for New Age Bank (NAB), conducted using the NIST SP 800-30 methodology, highlights the critical risks associated with third-party suppliers, ICT support contracts, and the physical security of NAB's headquarters. By identifying potential threats, vulnerabilities, and risk scenarios, this report provides a comprehensive evaluation of NAB's cybersecurity posture.

Key risks include supplier compromise leading to unauthorized access, supplier mishandling of sensitive information, unauthorized remote access via ICT contractors, and physical security threats such as unauthorized building access and insider sabotage. Each risk scenario has been thoroughly analyzed based on likelihood and impact, leading to the development of tailored mitigation strategies.

To strengthen NAB's cybersecurity defenses, recommended controls from NIST SP 800-53 have been applied, ensuring industry best practices are followed. These include robust third-party risk management, access control enforcement, multi-factor authentication, continuous monitoring, and enhanced physical security measures.

By implementing these mitigation strategies, NAB can significantly reduce its exposure to cybersecurity threats, enhance regulatory compliance, and maintain customer trust. This risk assessment provides a foundation for proactive cybersecurity improvements, ensuring that NAB's digital, physical, and human assets remain secure in an evolving threat landscape.

Reference

- **National Institute of Standards and Technology (NIST). (2012).** *Guide for Conducting Risk Assessments (NIST Special Publication 800-30, Revision 1)*. U.S. Department of Commerce. Retrieved from <https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final>
- **National Institute of Standards and Technology (NIST). (2020).** *Security and Privacy Controls for Federal Information Systems and Organizations (NIST Special Publication 800-53, Revision 5)*. U.S. Department of Commerce. Retrieved from <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>
- **European Union Agency for Cybersecurity (ENISA). (2019).** *Cybersecurity Risk Management: Methods for Assessing Risk*. ENISA. Retrieved from <https://www.enisa.europa.eu/publications/risk-management-standards>

Appendix

NAB – New Age Bank

CIA – Confidentiality, Integrity, and Availability

VPN – Virtual Private Network

MFA – Multi-Factor Authentication

IDS – Intrusion Detection System

IPS – Intrusion Prevention System

SIEM – Security Information and Event Management

SOC – Security Operations Center

NIST – National Institute of Standards and Technology

GDPR – General Data Protection Regulation